

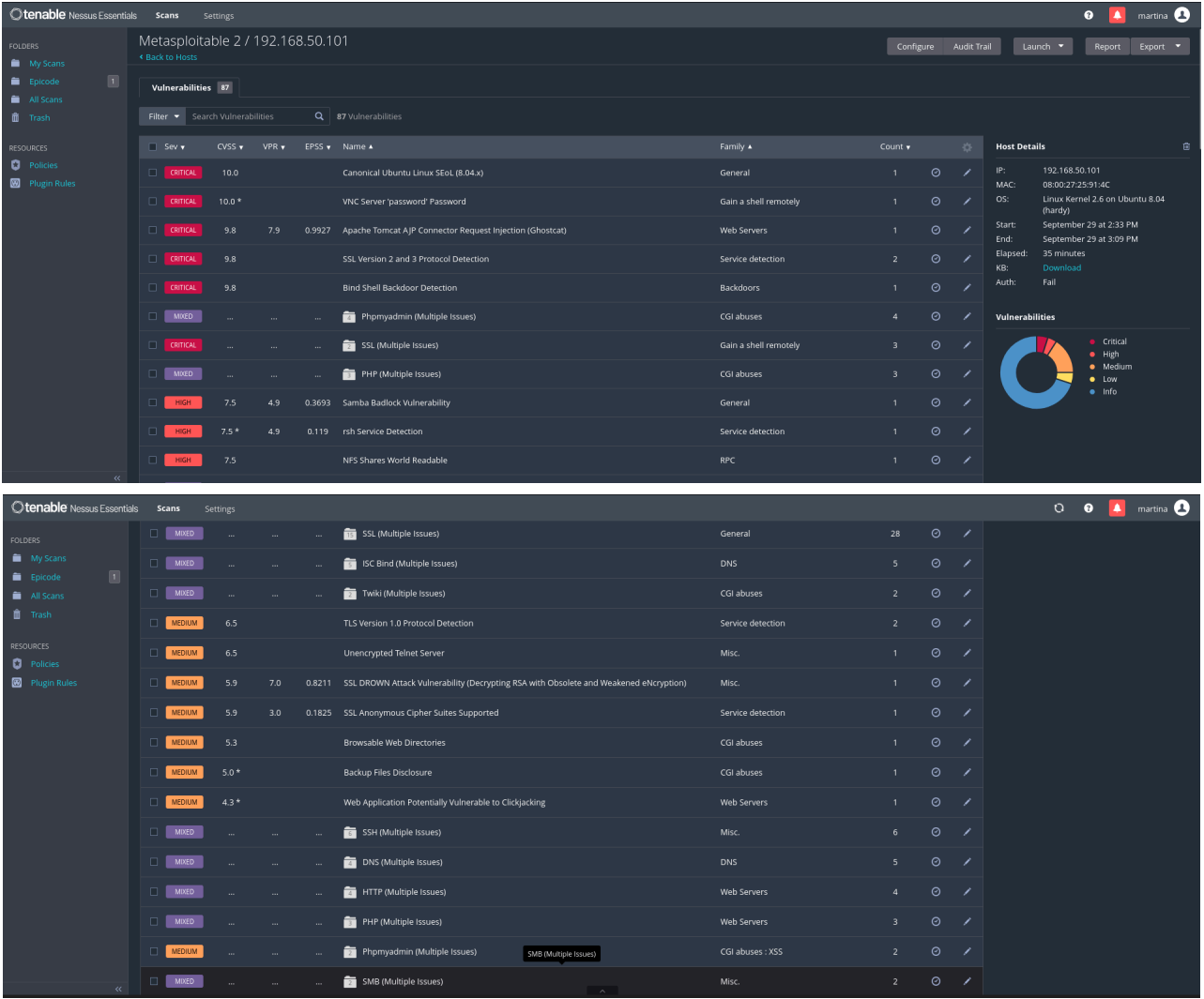
Scansione iniziale delle vulnerabilità Metasploitable 2

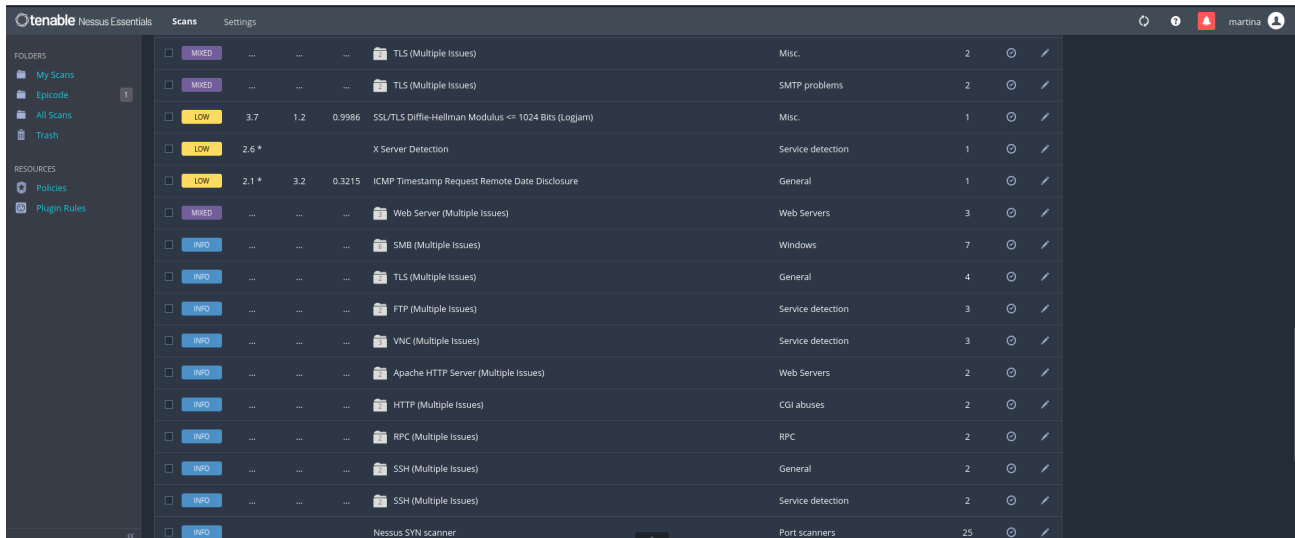
Report tecnico

Nome: Martina Foresta Corso: CyberSecurity	Attività: scansione iniziale e selezione delle vulnerabilità Target: Metasploitable 2 — 192.168.50.101
Data scansione: 29 settembre 2026 Orario Nessus: 14:33–15:09 Data report: 3 ottobre 2026	Durata riportata: 35 minuti Autenticazione Nessus: non riuscita (Auth: Fail)

Esito della scansione

Nessus riporta 87 risultati nella scheda Vulnerabilities dell'host 192.168.50.101. Per l'esercitazione sono state selezionate quattro voci contrassegnate Critical, scelte perché il dettaglio del plugin contiene riscontri specifici sui servizi esposti. La scansione è stata eseguita senza autenticazione riuscita. Al momento di questo report non era stata applicata alcuna remediation dopo la scansione.





Vulnerabilità scelte per la remediation

La severità Critical è la classificazione assegnata da Nessus. Per valutare questi quattro casi consideriamo anche l'output del plugin, le porte indicate e l'esito dei test riportati. La tabella riassume le prove iniziali e l'intervento previsto; le correzioni saranno documentate nel secondo report e verificate con una nuova scansione.

Risultato Nessus	Riscontro e rischio	Intervento previsto
Bind Shell Backdoor Detection Critical · Plugin 51988 1524/tcp	Nessus ha eseguito il comando <code>id</code> e ha ricevuto <code>uid=0(root), gid=0(root), groups=0(root)</code> . La shell risponde senza autenticazione con privilegi <code>root</code> .	Commentare la voce <code>ingeslock</code> in <code>/etc/inetd.conf</code> per disattivare la bind shell, riavviare <code>xinetd</code> e verificare da Kali che la porta 1524/tcp risulti closed.
VNC Server 'password' Password Critical · Plugin 61708 5900/tcp	Nessus dichiara di essersi autenticato al servizio VNC usando la password "password". Il plugin indica anche <code>Default Account: true</code> .	Cambiare la password VNC con una credenziale robusta e non riutilizzata. Se il servizio non serve, disattivarlo.
Apache Tomcat AJP Connector Request Injection (Ghostcat) Critical · Plugin 134862 8009/tcp	Nessus marca il test come riuscito e mostra una richiesta AJP di lettura di <code>WEB-INF/web.xml</code> con contenuto restituito dal server. CVSS 3.0: 9.8; VPR: 7.9; EPSS: 0.9927.	Disabilitare AJP se non è necessario; altrimenti aggiornare Tomcat e proteggere il connettore secondo la raccomandazione Nessus.
SSL Version 2 and 3 Protocol Detection Critical · Plugin 20007 25/tcp e 5432/tcp	Nessus riporta SSLv2 attivo su SMTP (25) e SSLv3 su PostgreSQL (5432). L'output elenca suite legacy/deboli, comprese suite export e cifrari RC4, MD5 e DES/3DES.	Limitare temporaneamente l'accesso a 25/tcp e 5432/tcp con due regole firewall e verificare da Kali che risultino filtered. La misura non disabilita SSLv2/SSLv3 nei servizi.

Verifica preliminare da Kali

Prima delle modifiche, da Kali è stato eseguito un controllo mirato delle cinque porte associate ai risultati selezionati:

```
nmap -sV -p 1524,5900,8009,25,5432 192.168.50.101
```

Nmap ha segnalato l'host come raggiungibile e tutte le porte controllate come open: 1524 bind shell, 5900 VNC, 8009 AJP, 25 SMTP e 5432 PostgreSQL (versione rilevata 8.3.0–8.3.7). Questo controllo conferma che i servizi rispondono dalla rete; da solo non verifica la password VNC, l'esito Ghostcat o i protocolli SSL.

```
(kali㉿kali)-[~]  
$ nmap -sV -p 1524,5900,8009,25,5432 192.168.50.101  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-03 13:26 -0400  
Nmap scan report for 192.168.50.101  
Host is up (0.0043s latency).  
  
PORT      STATE SERVICE      VERSION  
25/tcp    open  smtp         Postfix smtpd  
1524/tcp  open  bindshell    Metasploitable root shell  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)  
MAC Address: 08:00:27:25:91:4C (Oracle VirtualBox virtual NIC)  
Service Info: Host: metasploitable.localdomain  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 12.14 seconds
```

Stato e passaggi successivi

Questo documento fotografa la situazione iniziale e non dichiara risolte le vulnerabilità. Il passaggio successivo sarà applicare le remediation sulla Metasploitable 2. Una nuova scansione Nessus consentirà poi di confrontare i risultati.